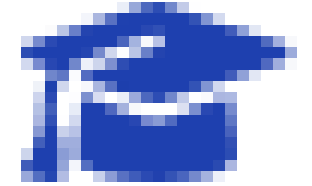


حوكمة الأمن السيبراني



الاسبوع الثالث

إطار NIST CSF 2.0 للأمن السيبراني ووظيفة الحوكمة (Govern)

أستاذ المادة

أ.د. ضياء جاسم كاظم

المحور الأول : نشأة NIST ونشأة الإطار CSF

فهم الجذور التاريخية والطبيعة التنظيمية للمعهد الوطني للمعايير والتقنية

NIST : National Institute of Standards and Technology
CSF: Cyber Security Framework

المعهد الوطني للمعايير والتقنية (NIST)

تعريف المعهد: وكالة فيدرالية أمريكية غير تنظيمية تتبع وزارة التجارة، تُعنى بتطوير لمعايير القياسية والتقنية لتعزيز الابتكار والأمن.

 **معايير مرجعية طوعية:** لا تملك صفة القانون الملزم بذاتها، ولكنها تُعتمد كمرجع عالمي رئيسي.

 **لغة مشتركة للشركات:** تتيح للمؤسسات بمختلف أحجامها تقييم نضجها الأمني وربطه بأهداف العمل.

 **المرونة والتكيف:** صُمم الإطار ليتناسب مع قطاعات التكنولوجيا، المالية، والصحية وغيرها.

التطور التاريخي لإطار NIST CSF

2024 - CSF 2.0

النقلة النوعية: توسع النطاق ليشمل جميع القطاعات، مع استحداث وظيفة الحوكمة (Govern).

2014 - CSF 1.0

النسخة الأولى: ركزت بشكل أساسي على حماية البنية التحتية الحيوية الطاقة، الاتصالات، الصحة.

2018 - CSF 1.1

التحديث الأولي: أضاف مفاهيم قياس المخاطر وإدارة مخاطر سلسلة التوريد والتقييم الذاتي.

المستجدات والتغيرات الجوهرية في CSF 2.0

إضافة وظيفة الحوكمة (Govern)

إفراد الحوكمة كوظيفة مستقلة ومركزية تُوجّه الوظائف الخمس الأخرى، لضمان ارتباط الأمن السيبراني بالاستراتيجية العليا للمؤسسة.

شمولية نطاق التطبيق

لم يعد الإطار حصرياً للبنى التحتية الحيوية، بل أصبح أدلة عالمية قابلة للتطبيق في الناشئة، المؤسسات الصغيرة، والشركات العالمية على حد سواء.

الهيكلة الجديدة والوظائف الست: المحور الثاني

استعراض البنية المفاهيمية لإطار CSF 2.0 وكيف تتكامل الوظائف التشغيلية

الوظائف الست الأساسية للإطار



1. الحوكمة (Govern)

تحديد الاستراتيجية، أولويات المخاطر، والسياسات، والمسؤوليات التوجيهية



2. التعرف (Identify)

حصر الأصول، الأجهزة، والبيانات، وفهم البيئة التشغيلية والمخاطر



3. الحماية (Protect)

وضع الضوابط الوقائية لضمان استمرار تقديم الخدمات الحيوية



5. الاستجابة (Respond)

اتخاذ الإجراءات الفورية واحتواء الحادث السيبراني والحد من أثره



6. التعافي (Recover)

استعادة القدرات والخدمات المتأثرة وتعزيز المرونة التنظيمية

4. الكشف (Detect)

تحديد وقوع الحوادث والأحداث السيبرانية الشاذة بشكل سريع ومباشر

INSIGHT GAP BECAME A HIGH PRIORITY, ARE BOARDS GOING BLIND?



الحوكمة في قلب الإطار السيبراني

السياق الاستراتيجي الموجه

في النسخة السابق 1.1، كانت عناصر الحوكمة مبعثرة ضمن وظيفة

التعرّف (ID.GV). أدركت NIST أن الأمن السيبراني ليس مجرد مهمة

تقنية لحماية الأجهزة، بل هو مسؤولية قيادية عليا.

تضع الحوكمة "شهية المخاطر" وتحدد الموارد والمسؤوليات التي تبنى

عليها باقي الوظائف الست : التعرف، الحماية، الكشف، الاستجابة،

والتعافي.



الفئات الست لوظيفة الحوكمة: المحور الثالث

CSF 2.0 في (GV Categories) تحليل دقيق وعميق للفئات التفصيلية

GV.OC : السياق التنظيمي (Organizational Context)

🎯 فهم رسالة المؤسسة وأهدافها : لا يمكن وضع حماية سيبرانية فعالة دون فهم طبيعة عمل المؤسسة، أهدافها التجارية، أو خدماتها الحكومية.

⚖️ الالتزامات القانونية والتنظيمية : حصر القوانين، اللوائح، والاشتراطات التعاقدية التي تجب مراعاتها (مثل أنظمة هيئة الأمن السيبراني .NCA)

👥 توقعات أصحاب المصلحة : تحديد متطلبات العملاء، الشركاء، والمستثمرين فيما يتعلق بالخصوصية والسرية.

🔗 ربط القرار السيبراني بالواقع التشغيلي : ضمان أن القرارات الأمنية تساند استمرارية الأعمال ولا تعوق الابتكار.

خيارات الاستجابة والافتراضات

تحديد الأطر العامة لمعالجة المخاطر: القبول، الحد، نقل الخطر
(كالتأمين السيبراني)، أو تجنب الخطر، وتوفير الميزانيات اللازمة
للتحويل.

شهية المخاطر (Risk Appetite)

تحديد حدود مستويات المخاطر السيبرانية التي تقبل الإدارة العليا
تحملها في سبيل تحقيق أهدافها المؤسسية، وتحديد سقف التحمل
(Risk Tolerance).

GV.RR : الأدوار والمسؤوليات والصلاحيات

آلية المساءلة	المسؤولية الجوهرية	المستوى التنظيمي
تقارير دورية عن حالة النضج والمخاطر العابرة.	اعتماد الاستراتيجية، إقرار شهية المخاطر، وتوفير الموارد.	مجلس الإدارة / القيادة العليا
مؤشرات الأداء الرئيسية (KPIs) ونسبة امتثال الضوابط.	تطوير وتطبيق برنامج الأمن السيبراني والإشراف التشغيلي.	الرئيس التنفيذي للأمن (CISO)
اختبارات التوعية والتدقيق الداخلي المستمر.	التنفيذ اليومي للسياسات والالتزام بالتعليمات الأمنية.	الفرق التشغيلية والموظفون

GV.PO : سياسات الأمن السيبراني التنظيمية

صياغة واعتماد السياسات : إعداد سياسات مكتوبة وشاملة تعكس التوجهات الاستراتيجية والمتطلبات التنظيمية.



التواصل والتوعية الشاملة : نشر السياسات وتعميمها على جميع الموظفين والمقاولين بأسلوب واضح ومفهوم.



الإنفاذ والإلزام : وضع آليات تحقق لضمان تطبيق السياسات مع وجود جزاءات واضحة للمخالفات.



المراجعة والتحديث الدوري : مراجعة السياسات سنوياً أو عند حدوث تغيرات تقنية وجوهرية في البيئة التشغيلية.



GV.OV : الرقابة والإشراف المستمر



استخدام نتائج التقييمات والتدقيق الدوري لتعديل وتحديث استراتيجية إدارة المخاطر وتوجيه القرار القيادي (Oversight) تتضمن وظيفة الرقابة

مع اعتماد المؤسسات على السحابة والموردين الخارجيين، أصبحت سلسلة التوريد من أكبر متجهات الهجوم. (Attack Vectors).

🔗 تقييم الموردين: إدراج المتطلبات الأمنية في العقود والاتفاقيات (SLAs)

 **المراقبة المستمرة: التحقق الدوري من النضج الأمني للطرف الثالث.**

خطة الطوارئ المشتركة: ضمان التنسيق في حال تعرض المورد لخرق
سيبراني.

أدوات التطبيق والقياس: المحور الرابع

كيف تحول المؤسسات الإطار النظري إلى ممارسة عملية مقاسة؟

مستويات تطبيق الإطار (Implementation Tiers)

4

مستويات لتحديد نضج إدارة المخاطر

- 1 المستوى (1 جزئي: Partial) - الممارسات عشوائية وردود أفعال غير مدونة.
- 2 المستوى (2 مستنير بالمخاطر: Risk Informed) - وجود سياسات لكن تطبيقها غير منتظم.
- 3 المستوى (3 قابل للتكرار: Repeatable) - ممارسات موثقة ومؤسسية ومطبقة بانتظام.
- 4 المستوى (4 متكيف: Adaptive) - الاستجابة الديناميكية والتعلم المستمر من التهديدات.

الملفات التعريفية (Profiles) وتحليل الفجوة



تحليل الفجوة وخطة العمل

مقارنة الملفين لتحديد الفجوات (Gaps)
وصياغة خطة خارطة طريق
(Roadmap) ذات أولويات ميزانية
تنفيذية.



الملف المستهدف (Target Profile)

تحديد الأهداف والأوضاع الأمنية المطلوب
الوصول إليها بناءً على شهية المخاطر
ومتطلبات العمل.



الملف الحالي (Current Profile)

توصيف دقيق ومباشر لحالة الضوابط
والممارسات الأمنية المطبقة فعلياً في
الوقت الراهن داخل المؤسسة.

سيناريو تطبيقي: الحوكمة في الممارسة العلمية



1. التوجيه القيادي

يقوم المجلس بوضع شهية المخاطر واعتماد الاستراتيجية والسياسات العامة للأمن السيبراني.



2. التنفيذ التشغيلي

يقوم فريق CISO بتطبيق ضوابط Protect & Detect استناداً للسياسات المعتمدة.

7	Asset management policy breach		
8	Non-disclosure / confidentiality breach		
9	Systems access breach		
10	Building access breach		
11	Visitor access issues		
12	Identification badge / keyless entry issues		
13	Non-public printed material security issues		
14	System change procedure issues		
15	Routine testing problems		
16	Password protection / system handover		
17	Password sharing issues		
18	Third party access / breach of non-public data		

3. الرقابة والتقييم

رفع تقارير الأداء ومراجعة مخاطر الموردين لتعديل الاستراتيجية وتحديثها بشكل دوري.

المحور الخامس: الخلاصة والآفاق المستقبلية

أبرز التوصيات الأكاديمية والمفاهيم المحورية للمحاضرة